

QUICK REFERENCE: AI Policy Checklist

Generative AI for Business Leaders & C-Suite | AI Governance & Policy

1. Why Every Organisation Needs an AI Policy Now

Generative AI tools are already inside your organisation, whether you have sanctioned them or not. A 2024 survey by Salesforce found that more than half of employees using generative AI at work had not received approval to do so. They are pasting customer data into ChatGPT to draft emails, uploading financial spreadsheets to AI analytics tools, and using AI code generators without understanding how those tools handle proprietary information. The absence of a policy is itself a policy — one that says 'anything goes.'

An AI policy does three things simultaneously. First, it protects the organisation from legal, regulatory, and reputational risk by establishing boundaries around data handling, output review, and disclosure. Second, it empowers employees to use AI confidently by removing the ambiguity that makes cautious people avoid AI entirely and reckless people use it unsafely. Third, it creates accountability — when expectations are written down, enforced, and communicated, every employee knows where the lines are and what happens when they are crossed.

Key Point: A well-designed AI policy is not a restriction on innovation. It is the infrastructure that makes responsible innovation possible at scale. Without it, you are relying on individual judgment across hundreds or thousands of employees — and individual judgment is inconsistent, uninformed, and legally indefensible.

2. Policy Area 1 — Acceptable Use Guidelines

Acceptable use guidelines are the foundation of your AI policy. They answer the question every employee has the moment they hear about a new AI tool: 'Am I allowed to use this, and what can I do with it?'

The six essential elements

Element	What It Covers	Why It Matters
Approved vs. Prohibited Tools	An explicit list of AI tools employees may use (e.g., enterprise ChatGPT, Copilot) and those that are banned (e.g., free consumer AI tools for business data)	Employees use what is convenient unless told otherwise. Without a list, they default to whatever free tool they find first.
Data Handling Rules	Three categories: data that must never enter AI (PII, financial records, trade secrets), data requiring approval, and data safe for AI use	The most common AI incident — and the easiest to prevent — is employees pasting sensitive data into tools that store it externally.
Output Review	Which AI outputs require human	AI outputs range from harmless (internal

Requirements	review before use, and who must conduct the review	meeting notes) to high-risk (client-facing legal advice). Review requirements must match the risk.
Attribution and Disclosure	When employees must disclose that content was AI-generated, especially for client-facing or published material	Undisclosed AI use creates legal and reputational risk when discovered, as the Air Canada chatbot case demonstrated.
Prohibited Uses	Explicit list: no final legal advice, no medical diagnoses, no financial decisions, no automated decisions about people — all without human review	Employees may not realise that using AI for certain decisions carries legal liability. Explicit prohibitions prevent well-intentioned misuse.
Consequences for Violations	Clear, proportionate consequences for policy breaches, from verbal warnings to termination depending on severity	Policies without enforcement mechanisms are suggestions. Employees take policies seriously when consequences are real and known.

The simplicity test

Your acceptable use guidelines pass the simplicity test if a new employee can read them in under ten minutes and correctly answer: 'Can I use AI for this specific task?' If the answer requires consulting a 40-page document, cross-referencing three appendices, or asking a manager who also is not sure, the policy is too complex to be followed. Simple policies get followed. Complex policies get ignored.

3. Policy Area 2 — Data Classification and Handling

Data classification is the single most impactful element of an AI policy because the majority of AI-related incidents involve data mishandling — putting the wrong data into the wrong tool. A three-tier classification scheme balances security with usability.

Tier	Classification	AI Tool Access	Examples
Tier 1	Public Data — already publicly available	Any AI tool, including free consumer versions	Published marketing materials, public website content, openly available research
Tier 2	Internal Data — not public, not highly sensitive	Approved enterprise AI tools with data protection agreements only	Internal emails, meeting notes, draft documents, general business analysis
Tier 3	Confidential Data — sensitive and restricted	Requires specific approval and additional safeguards before any AI use	Customer PII, financial records, trade secrets, strategic plans, legal documents, employee data

The decision tree approach

Classification is only useful if employees can apply it quickly. Design a three-question decision tree that any employee can follow:

- **Question 1:** Is this data already publicly available? If yes → Tier 1 (Public). Use any AI tool.
- **Question 2:** Does this data contain personal information, financial details, legal content, or competitive intelligence? If yes → Tier 3 (Confidential). Requires approval.
- **Question 3:** If neither public nor confidential → Tier 2 (Internal). Use approved enterprise tools only.

Post this decision tree in break rooms, include it in email signatures during rollout, and build it into the AI tool selection screen. Make the right decision the easy decision.

Real-World Incident — Samsung Semiconductor (2023): Samsung engineers pasted proprietary semiconductor source code and confidential meeting notes into ChatGPT to assist with debugging and summarisation. The data entered OpenAI's systems, where it could potentially be used in model training. Samsung subsequently banned all generative AI tools — an overcorrection that cost the company productivity while competitors moved ahead. A simple data classification scheme would have prevented the incident: source code and internal meeting notes are clearly Tier 3 (Confidential) data that should never enter consumer AI tools without explicit approval and data protection guarantees.

4. Policy Area 3 — Tool Approval Process

New AI tools appear weekly. Without a clear approval process, two problems emerge: employees adopt unapproved tools (shadow AI), or the approval process is so slow that employees circumvent it out of frustration. Both outcomes are governance failures.

Five questions the process must answer

- **Who can request new tools?** Deciding whether only managers can submit requests or any employee can affects both innovation speed and request volume. Most organisations benefit from allowing any employee to request but requiring manager endorsement.
- **What information must accompany a request?** At minimum: tool name, vendor, intended use case, types of data involved, estimated cost, and number of users. This gives evaluators what they need without creating a bureaucratic obstacle.
- **Who evaluates requests?** Typically a combination of IT security (data protection), legal or compliance (regulatory alignment), and the requesting business unit (value justification). Small organisations might combine these into a single cross-functional reviewer.
- **What are the evaluation criteria?** Security and data handling, compliance certifications (SOC 2, GDPR compliance), vendor stability and reputation, integration capabilities, and cost-benefit assessment.
- **What is the timeline?** Best practice is a decision within two weeks. If your process routinely takes months, people will work around it. Speed is a feature of good governance, not a threat to it.

The two-week rule

A tool approval process that takes longer than two weeks for standard requests is broken. Every week of delay increases the probability that an employee will adopt the tool without approval, creating exactly the ungoverned risk the process was designed to prevent. If your evaluation requires external security assessments or legal review of vendor contracts, run these in parallel, not sequentially. Set a two-week target, measure against it, and treat repeated misses as a governance deficiency.

5. Policy Area 4 — Training and Awareness

Policies work only when people understand them. Training transforms a document that sits on an intranet into operational behaviour across the organisation.

Five elements of effective AI training

Element	Content	Delivery Method
AI Basics and Capabilities	What AI is, what it can do, and critically what it cannot do. Correct common misconceptions.	60-minute interactive session with live demos
Risk Awareness	Real examples of AI failures (Samsung, Air Canada, biased hiring tools). Why each policy rule exists.	Case study workshop with discussion
Organisation-Specific Policies	Your acceptable use rules, data classification, tool approval, review requirements — with practical examples from your business.	Self-paced e-learning with knowledge check
Hands-On Practice	Guided use of approved AI tools on safe data. Let people experience AI's strengths and limitations firsthand.	Supervised lab session with facilitator
Department-Specific Guidance	How AI applies to marketing, finance, HR, legal, operations — different roles face different opportunities and risks.	Team-level workshops led by department AI champions

Multi-layered delivery

A single annual training session is insufficient. Effective AI literacy requires multiple touchpoints: onboarding training for new employees, annual refreshers for all staff, role-specific deep dives for high-risk functions (legal, finance, HR), and just-in-time resources like quick reference cards, FAQs, and a Slack channel or inbox where employees can ask questions in real time. The quick reference card — a one-page document summarising data classification, approved tools, and the review workflow — is often the most-used training artefact because it answers questions at the moment they arise.

6. Policy Area 5 — Incident Reporting and Response

Even with strong policies, incidents will occur. What separates well-governed organisations from poorly governed ones is not the absence of incidents — it is the speed and quality of their response.

Defining an AI incident

An AI incident is any event where AI use causes or could cause harm to the organisation, its employees, customers, or partners. Common categories include:

- Sensitive data exposed to an unapproved AI tool

- An AI-generated output containing a significant factual error that reached external audiences
- A policy violation (e.g., using a banned tool, skipping required review)
- A security breach involving AI systems (prompt injection, data extraction)
- Discriminatory or biased AI output that affected a decision about a person

Response protocol

Step	Action	Timeline
1. Report	Employee reports incident via a simple form or dedicated email. No blame, no consequences for reporting.	Immediately upon discovery
2. Triage	AI policy owner assesses severity (high/medium/low) and determines whether the incident requires immediate containment	Within 4 hours for high-severity, 24 hours for others
3. Contain	Stop the immediate harm — revoke access, correct the output, notify affected parties if needed	Concurrent with triage for high-severity
4. Investigate	Determine root cause: Was it a policy gap, a training failure, a tool deficiency, or a deliberate violation?	Within 5 business days
5. Remediate	Fix the root cause — update the policy, retrain the team, reconfigure the tool, or take personnel action	Within 10 business days
6. Document	Record the incident, root cause, and resolution. Feed learnings into policy updates and training.	Within 15 business days

The most important design principle is making reporting easy and consequence-free. If employees fear punishment for reporting incidents, they will hide them — and hidden incidents fester into larger problems. Celebrate reporting. The employee who reports an AI incident is protecting the organisation, not embarrassing it.

7. Policy Area 6 — Audits and Continuous Improvement

AI technology evolves rapidly. A policy written in January may be inadequate by June if new tools, new regulations, or new use cases have emerged. Regular audits ensure the policy remains relevant and effective.

Audit cadence

- **Quarterly:** Review AI usage patterns (which tools, which departments, what data). Review incident reports and trends. Assess whether policies are being followed. Identify new use cases that need policy guidance.
- **Annually:** Comprehensive audit of the entire AI governance framework. Benchmark against industry standards and regulatory requirements. Assess training effectiveness. Review vendor contracts and data handling practices.
- **Continuously:** Monitor AI output quality through automated metrics. Track user feedback and satisfaction. Watch for regulatory changes that require policy updates.

Each audit cycle should produce a short action report: what was reviewed, what was found, what changes are recommended. Publish these internally. Transparency about your own governance process builds organisational confidence in the AI programme and demonstrates accountability to stakeholders.

8. Building Your Checklist — The Priority Matrix

Not all six policy areas need to be completed simultaneously. For organisations starting from scratch, the following priority sequence maximises risk reduction per unit of effort.

Priority	Policy Area	Rationale
1 (Immediate)	Data Classification & Handling	Data leakage is the most common and most damaging AI incident. This policy prevents the worst outcomes fastest.
2 (Week 1-2)	Acceptable Use Guidelines	Employees need to know what they can and cannot do. Clarity reduces both over-caution and recklessness.
3 (Week 2-4)	Tool Approval Process	Prevents shadow AI adoption and ensures all tools meet security and compliance requirements.
4 (Month 1-2)	Training and Awareness	Policies only work when people understand them. Training converts documents into behaviour.
5 (Month 2-3)	Incident Reporting & Response	Incidents will happen. Being prepared reduces harm and accelerates learning.
6 (Ongoing)	Audits and Continuous Improvement	The policy must evolve with the technology. Build the review cadence from day one.

This is a recommended sequence, not a rigid prescription. If your organisation has already experienced a data incident, Policy Area 2 (Data Classification) is your day-one priority. If employees are already using AI tools without any guidance, Policy Area 1 (Acceptable Use) comes first. Let your risk profile determine your sequence.

9. Common Policy Pitfalls

- **Writing policies that are too long or too complex:** If your AI policy is 50 pages, nobody will read it. Aim for a core policy document of 5-10 pages with supporting appendices for specific topics. The main document should be readable in 15 minutes.
- **Banning AI entirely:** Blanket bans do not stop AI use — they drive it underground where it is completely ungoverned. Samsung's ban after their data leak incident did not eliminate AI usage; it eliminated visibility into AI usage. Governance is safer than prohibition.
- **Creating policies without enforcement:** A policy without consequences is a suggestion. If violations have no meaningful response, compliance is optional. Enforcement does not mean draconian punishment — it means consistent, proportionate consequences that signal the policy matters.
- **Failing to update the policy:** AI capabilities and risks change faster than almost any other technology area. A policy written in early 2024 may not address multimodal AI, AI agents, or new regulatory requirements that emerged by late 2024. Build review cycles into the policy itself.

- **Ignoring department-specific needs:** A one-size-fits-all policy fails legal, HR, finance, and marketing in different ways. Each department faces unique AI risks and opportunities. Supplement the core policy with department-specific guidance.

10. Key Terms Glossary

Term	Definition
Acceptable Use Policy	A formal document defining what employees are permitted and prohibited from doing with AI tools, including approved tools, data restrictions, and review requirements.
Shadow AI	The use of AI tools by employees without organisational approval or oversight, often occurring when formal adoption channels are too slow or restrictive.
Data Classification	A systematic framework for categorising data by sensitivity level to determine appropriate handling, storage, and AI access rules.
Tool Approval Process	A defined workflow for evaluating, approving, or rejecting new AI tools before they are used with organisational data.
Incident Response Protocol	A predefined sequence of steps for detecting, containing, investigating, and remediating AI-related incidents.
AI Audit	A systematic review of an organisation's AI usage, governance practices, and policy compliance, conducted at defined intervals.
PII (Personally Identifiable Information)	Any data that can identify a specific individual, including names, addresses, identification numbers, and financial records.
SOC 2 Compliance	A security certification standard for service providers that demonstrates controls over data security, availability, processing integrity, confidentiality, and privacy.

11. Quick Revision Checklist

- Six policy areas form a complete AI governance framework: acceptable use, data classification, tool approval, training, incident response, and audits.
- Acceptable use guidelines must cover six elements: approved/prohibited tools, data rules, output review, attribution, prohibited uses, and consequences.
- The simplicity test: if a new employee cannot answer 'Can I use AI for this?' within ten minutes of reading the policy, it is too complex.
- Three-tier data classification (Public, Internal, Confidential) balances security with usability. Provide a decision tree, not a manual.
- Tool approval should take two weeks or less. Longer timelines drive shadow AI adoption.
- Training must be multi-layered: onboarding, annual refresher, role-specific, and just-in-time reference materials.
- Make incident reporting easy and consequence-free for reporters. Hidden incidents are far more dangerous than reported ones.
- Quarterly usage reviews plus annual comprehensive audits keep the policy current as AI technology evolves.

- Start with data classification if building from scratch — data leakage is the most common and most damaging incident category.
- Blanket AI bans do not work. They drive usage underground where it is completely ungoverned. Governance is always safer than prohibition.

20 Exam-Based MCQs — AI Policy Checklist

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. What is the PRIMARY purpose of an AI acceptable use policy?

- A) To prevent all employees from using AI tools
- B) To define clear boundaries for AI use, empowering employees to use AI confidently while protecting the organisation from risk
- C) To comply with government regulations that mandate AI policies
- D) To document which AI vendor the organisation has selected

Answer: B **Explanation:** B is correct because an acceptable use policy serves a dual purpose: risk protection through boundaries, and employee empowerment through clarity. Without it, cautious employees avoid AI entirely while reckless employees use it unsafely. A is wrong because the policy enables responsible use, not prohibition. C is wrong because while regulatory compliance may be a benefit, the primary purpose is operational governance. D is wrong because vendor selection is a procurement decision, not a policy function.

Q2. *Scenario:* A sales representative at a software company needs to prepare a proposal for a major client. She wants to use ChatGPT to draft the proposal, which will include the client's budget figures, current technology infrastructure details, and competitive analysis. The company has no AI policy in place. What is the MOST significant risk in this situation?

- A) The proposal might contain grammatical errors
- B) Confidential client data (budget figures, infrastructure details) could be exposed to a third-party AI tool without any data handling safeguards
- C) The client might prefer a human-written proposal
- D) The AI might generate a proposal that is too long

Answer: B **Explanation:** B is correct because client budget figures and infrastructure details are confidential data that should never enter a consumer AI tool without data protection agreements. Without a policy, the sales rep has no guidance on data classification or tool approval. A is a minor quality issue. C is a preference issue, not a governance risk. D is trivially fixable.

Q3. Under the three-tier data classification scheme, which tier would internal meeting notes typically fall into?

- A) Tier 1 — Public Data

- B) Tier 2 — Internal Data
- C) Tier 3 — Confidential Data
- D) It depends on whether the meeting was recorded

Answer: B **Explanation:** B is correct because internal meeting notes are not publicly available (ruling out Tier 1) but are generally not highly sensitive (ruling out Tier 3 for routine meetings). They can be used with approved enterprise AI tools that provide data protection. A is wrong because meeting notes are not public. C would apply only if the meeting involved confidential topics (M&A, personnel decisions, legal strategy). D is irrelevant to classification — the content determines the tier, not the recording method.

Q4. Scenario: *A pharmaceutical company has a comprehensive AI policy. Their tool approval process works well but takes an average of eight weeks from request to decision. During a company survey, 40% of employees admit to using unapproved AI tools because they 'cannot wait that long.'* What does this situation indicate?

- A) Employees lack discipline and need stricter enforcement
- B) The tool approval process is too slow, driving shadow AI adoption — the process is a governance failure, not the employees
- C) The company should ban all AI tools until the process improves
- D) Eight weeks is an acceptable timeline for tool approval

Answer: B **Explanation:** B is correct because a tool approval process that drives 40% of employees to circumvent it has failed at its core purpose. Best practice is a two-week decision timeline. When the process is too slow, shadow AI is the predictable result — and shadow AI is far more dangerous than approved-but-quickly-evaluated tools. A blames users for a systemic failure. C would increase shadow AI, not reduce it. D ignores the evidence that eight weeks is causing non-compliance.

Q5. Why is the 'simplicity test' important for AI acceptable use guidelines?

- A) Simple policies are cheaper to print
- B) Regulators require policies to be under a certain word count
- C) If employees cannot quickly determine whether a specific AI use is permitted, they will either avoid AI entirely or use it without checking — both governance failures
- D) Simple policies demonstrate that the organisation is not serious about AI governance

Answer: C **Explanation:** C is correct because policy effectiveness depends on employees actually using it. Complex policies create two equally bad outcomes: over-cautious employees who avoid AI (losing productivity) and under-cautious employees who ignore the policy (creating risk). A is trivial. B is incorrect — no such requirement exists. D inverts the truth — simplicity demonstrates mature governance that prioritises usability.

Q6. Scenario: *A retail company's HR director wants to use an AI tool to screen job applications. The company's AI policy prohibits 'automated decisions about people without human oversight.'* The HR

director argues that the AI is not making decisions — it is only ranking candidates, and humans will make the final hiring decision. Is the HR director's interpretation correct?

- A) Yes — ranking is not a decision, so the prohibition does not apply
- B) No — AI ranking that determines which candidates humans see is itself a consequential decision that can embed bias and exclude qualified candidates
- C) Yes — as long as the AI uses only publicly available data
- D) No — AI should never be used in hiring under any circumstances

Answer: B **Explanation:** B is correct because AI ranking determines which candidates reach the human decision-maker. If the AI's ranking is biased (and hiring models frequently are), qualified candidates from underrepresented groups may never reach the interview stage. This is an automated decision about people that requires oversight, review for bias, and transparency. A incorrectly separates ranking from decision-making. C is wrong because data source does not determine whether the use is consequential. D is overly restrictive — AI can assist in hiring with appropriate governance.

Q7. What is shadow AI?

- A) AI systems that operate in dark web environments
- B) AI tools used by employees without organisational approval or oversight
- C) A type of AI that works in the background of approved applications
- D) AI systems that have been officially deprecated but remain in use

Answer: B **Explanation:** B is correct because shadow AI refers to employees adopting AI tools outside of formal governance channels — analogous to 'shadow IT.' It typically occurs when approval processes are too slow, policies are unclear, or employees are unaware that policies exist. A confuses 'shadow' with dark web activity. C describes background processing, not ungoverned use. D describes legacy systems, a different governance challenge.

Q8. Scenario: *A financial services company experiences an AI incident: a junior analyst pasted client portfolio data into an unapproved AI tool. The analyst's manager wants to terminate the analyst immediately as a warning to others. The compliance officer suggests investigating first. What is the BEST course of action?*

- A) Terminate the analyst immediately to set an example
- B) Investigate the root cause first — determine whether the policy was clearly communicated, whether the analyst received training, and whether the approved tools met the analyst's workflow needs
- C) Ignore the incident since no client data was actually compromised
- D) Ban the entire department from using AI

Answer: B **Explanation:** B is correct because the incident response protocol requires investigation before remediation. If the analyst was never trained, never received the policy, or was using an unapproved tool because the approved tools did not support their workflow, the root cause is organisational, not individual. Terminating without investigation punishes the person while leaving the systemic failure intact. A is disproportionate without investigation. C ignores the policy violation regardless of outcome. D is a blanket

overreaction.

Q9. What is the recommended maximum timeline for a standard AI tool approval decision?

- A) One business day
- B) Two weeks
- C) Two months
- D) Six months

Answer: B **Explanation:** B is correct because two weeks balances thorough evaluation with the practical need for speed. Longer timelines drive shadow AI adoption. A is unrealistically fast for meaningful security and compliance review. C and D are too slow and will cause employees to circumvent the process.

Q10. *Scenario:* A consulting firm has implemented all six AI policy areas. During the quarterly audit, the governance team discovers that the AI training programme has a 95% completion rate but the post-training knowledge assessment shows that only 60% of employees can correctly classify data into the three tiers. What does this finding suggest?

- A) The training programme is effective — 95% completion is excellent
- B) The data classification framework should be simplified to two tiers
- C) The training content on data classification is insufficient — high completion does not equal high comprehension, and the classification framework may need clearer examples or a simpler decision tree
- D) The knowledge assessment is too difficult and should be made easier

Answer: C **Explanation:** C is correct because completion rate measures attendance, not understanding. A 40% failure rate on data classification — the most critical policy element — indicates that the training needs redesign: more practical examples, hands-on exercises, a simpler decision tree, or repeated reinforcement. A conflates attendance with effectiveness. B is premature — the tiers may be appropriate if taught better. D masks the problem rather than solving it.

Q11. Why is making incident reporting consequence-free for reporters essential?

- A) Because reporting is not important enough to require consequences
- B) Because employees who fear punishment for reporting will hide incidents, allowing small problems to grow into large ones
- C) Because all AI incidents are minor and do not warrant consequences
- D) Because consequence-free reporting is legally required in all jurisdictions

Answer: B **Explanation:** B is correct because hidden incidents are far more dangerous than reported ones. If an employee pasted customer data into an unapproved tool and fears termination for reporting it, the organisation loses the opportunity to contain the exposure, investigate the root cause, and prevent recurrence. A mischaracterises the importance of reporting. C is wrong because AI incidents can be severe. D is wrong because this is a governance best practice, not a universal legal requirement.

Q12. Scenario: A technology company's legal department discovers that their AI policy was written 18 months ago and has not been updated. Since then, the company has adopted three new AI tools, the EU AI Act has come into effect, and two departments have begun using AI for customer-facing decisions that were not anticipated when the policy was written. What is the MOST appropriate response?

- A) The policy is still valid since it was comprehensive when written
- B) Conduct an immediate comprehensive audit and update the policy to address new tools, new regulations, and new use cases
- C) Scrap the existing policy and start over from scratch
- D) Wait for the next scheduled annual review

Answer: B **Explanation:** B is correct because 18 months of unaddressed changes — new tools, new regulations, new use cases — represent significant governance gaps. An immediate audit identifies what needs updating. A is wrong because policies must evolve with the technology and regulatory landscape. C is wasteful — the existing policy provides a foundation that needs updating, not replacement. D is wrong because the gaps are too significant and too risky to leave unaddressed until the next scheduled review.

Q13. According to the Salesforce survey cited, approximately what proportion of employees using AI at work had not received organisational approval?

- A) About 10%
- B) About 25%
- C) More than 50%
- D) About 75%

Answer: C **Explanation:** C is correct — the 2024 Salesforce survey found that more than half of employees using generative AI at work had done so without receiving approval. This underscores the urgency of having clear, accessible AI policies. A and B underestimate the scale. D overstates it.

Q14. Scenario: A hospital is developing an AI policy. The head of IT proposes a single set of acceptable use guidelines for the entire hospital. The chief medical officer argues that clinical departments need different rules than administrative departments. Who is correct, and why?

- A) The head of IT — a single policy ensures consistency
- B) The chief medical officer — clinical AI use involves patient safety, regulatory requirements (HIPAA), and ethical considerations that require department-specific guidance on top of the core policy
- C) Neither — hospitals should not use AI at all
- D) Both are correct — the solution is to ban AI in clinical departments only

Answer: B **Explanation:** B is correct because a core policy provides the foundation, but clinical departments face unique risks (patient safety, HIPAA, medical liability) that require specific guidance. Administrative use of AI (meeting notes, scheduling) has fundamentally different risk profiles from clinical use (diagnostic support, treatment recommendations). A ignores meaningful differences in risk. C is unrealistic and counterproductive. D unnecessarily restricts clinical innovation.

Q15. What are the three components of the recommended AI incident response timeline?

- A) Report within a week, investigate within a month, remediate within a quarter
- B) Triage within 4-24 hours depending on severity, investigate within 5 business days, remediate within 10 business days
- C) Report immediately, remediate immediately, investigate later
- D) No specific timeline is needed as long as incidents are eventually addressed

Answer: B **Explanation:** B is correct — the recommended protocol specifies triage within 4 hours for high-severity (24 hours for others), investigation within 5 business days, and remediation within 10 business days. A is too slow. C skips investigation, risking repeated incidents. D lacks the urgency that incident response requires.

Q16. *Scenario:* A manufacturing company has written a 55-page AI policy covering every conceivable scenario. Six months after publication, an internal survey reveals that only 12% of employees have read beyond the first five pages. Meanwhile, three AI-related incidents have occurred, all involving employees who said they were 'not sure what the policy required.' What is the root cause of these incidents?

- A) Employees are negligent and should be disciplined
- B) The policy is too complex — at 55 pages, it fails the simplicity test and employees cannot practically use it for day-to-day decisions
- C) The company needs a more restrictive policy
- D) The incidents would have occurred regardless of policy length

Answer: B **Explanation:** B is correct because a policy that 88% of employees do not read past five pages is functionally non-existent. The incidents stem from a policy design failure, not employee negligence. A blames individuals for a systemic problem. C would make the policy even less usable. D ignores the clear connection between unread policies and uninformed behaviour.

Q17. Why is banning AI entirely — as Samsung did after their data leak — considered an overcorrection?

- A) Because bans are illegal under labour law
- B) Because blanket bans drive AI usage underground where it is completely ungoverned, creating greater risk than managed adoption
- C) Because Samsung's competitors all use AI
- D) Because AI bans are impossible to enforce technically

Answer: B **Explanation:** B is correct because prohibition does not eliminate demand — it eliminates visibility and governance. Employees who were using AI before a ban will continue using it through personal devices, personal accounts, and workarounds. The organisation loses all ability to monitor, guide, or protect against misuse. A is incorrect as a legal claim. C is a competitive argument, not a governance one. D is partially true but not the core reason — even if enforcement were possible, prohibition is still worse than governance.

Q18. Scenario: A government agency is implementing an AI policy. The training coordinator proposes a single one-hour online training module for all 5,000 employees, with no follow-up or reference materials. Why is this training approach insufficient?

- A) One hour is not enough time — training should be at least eight hours
- B) A single training event without follow-up, role-specific guidance, or reference materials fails to create lasting behaviour change — employees need multi-layered, ongoing support
- C) Online training is never effective — only in-person training works
- D) Government employees require different training than private sector employees

Answer: B Explanation: B is correct because effective training requires multiple touchpoints: initial training, role-specific guidance for high-risk functions, just-in-time reference materials, and periodic refreshers. A single session creates awareness but not competence. A focuses on duration rather than delivery model. C is wrong because online training can be effective as one component. D introduces an irrelevant distinction.

Q19. If building an AI policy from scratch, which policy area should typically be addressed FIRST?

- A) Training and Awareness
- B) Audits and Continuous Improvement
- C) Data Classification and Handling
- D) Tool Approval Process

Answer: C Explanation: C is correct because data leakage is the most common and most damaging AI incident category. Establishing data classification rules first provides the maximum risk reduction per unit of effort. A requires policies to exist before training on them. B is ongoing and requires a framework to audit. D is important but secondary to ensuring sensitive data is protected immediately.

Q20. Scenario: A financial advisory firm has just completed all six policy areas and published their AI governance framework. The managing partner asks: 'Are we done?' What is the correct answer?

- A) Yes — the policy is complete and can remain unchanged
- B) Almost — once all employees complete training, the work is done
- C) No — AI governance is an ongoing process requiring quarterly reviews, annual audits, continuous monitoring, and policy updates as technology and regulations evolve
- D) No — the firm should hire a permanent AI governance team of at least 10 people before considering the work complete

Answer: C Explanation: C is correct because AI governance is inherently continuous. Technology capabilities change, new use cases emerge, regulations evolve, and lessons from incidents require policy updates. Policy Area 6 (Audits and Continuous Improvement) exists precisely because governance is never 'done.' A ignores the dynamic nature of AI. B treats training as the final step rather than an ongoing requirement. D prescribes a specific staffing level that depends on organisation size and complexity.